

DATA PROTECTION ADDENDUM

This Data Processing Addendum ("DPA") forms part of the Agreement between **AML DEALCHECK LIMITED**, A COMPANY REGISTERED IN ENGLAND WITH COMPANY NUMBER 15893339 AND WHOSE REGISTERED OFFICE IS AT 71-75 SHELTON STREET, COVENT GARDEN, LONDON WC2H 9JQ ("**We**", "**Us**", or "**Our**") and you as the recipient of the Software defined in the Agreement ("**You**" or "**Your**") and governs Our Processing of Protected Data (as defined below) when fulfilling Our obligations under the Agreement. Any other capitalised expression used herein but not defined herein will bear the meaning given to it in the Agreement.

1. ADDITIONAL DEFINITIONS

In this DPA:

"**Controller**", "**Data Subject**", "**Personal Data**", "**Personal Data Breach**", "**Processor**", "**Processing**", and "**Supervisory Authority**" are each as defined in the GDPR (and "**Process**", "**Processed**", and "**Processes**" will each be interpreted accordingly);

"**Data Protection Legislation**" means all applicable data protection and privacy legislation in force from time to time, including without limitation the GDPR and the Data Protection Act 2018;

"**GDPR**" means, as applicable: (A) the European Union's General Data Protection Regulation (Regulation (EU) 2016/679); and/or (B) the UK GDPR, as defined in section 3(10) (as supplemented by section 205(4)) of the Data Protection Act 2018;

"**Protected Data**" means the Personal Data provided or made available by You to Us and Processed by Us on Your behalf in the performance of Our obligations under this Agreement (and the details of the relevant types of such Personal Data and the categories of the relevant Data Subjects are further described in paragraph 2 of this DPA);

"**Standard Contractual Clauses**" means as applicable: (i) the standard contractual clauses for the transfer of Personal Data to third countries pursuant to the GDPR, as adopted by the European Commission under Commission Decision (EU) 2021/914 2021 ("**EU SCCs**"); and (ii) the International Data Transfer Addendum to the EU SCCs issued by the Information Commissioner's Office under section 119A(1) of the Data Protection Act, and which is available at <https://ico.org.uk/media/for-organisations/documents/4019539/international-data-transfer-addendum.pdf>; and

"**Security Page**" means the Security Page at the end of this Data Protection Addendum detailing Our technical and organisational information security measures (as updated from time to time) as the same may be included on our website notified to You from time to time.

2. PERSONAL DATA TYPES AND PROCESSING PURPOSES

- 2.1 For the purposes of the Data Protection Legislation, You are the Controller and We are the Processor of the Protected Data.
- 2.2 You retain control of the Protected Data and remain responsible for Your compliance obligations under the applicable Data Protection Legislation, including providing and obtaining any required notices and consents, and for the Processing instructions You give to Us.
- 2.3 You warrant and represent that Our expected use of the Protected Data for the provision of the Software and as specifically instructed by You will comply with the Data Protection Legislation.
- 2.4 The subject matter of the Processing of the Protected Data is to enable Us to perform Our obligations under this Agreement and the relevant Order Form, and the duration of such Processing is for the Subscription Term and any Renewal Term of the relevant Order Form. The nature of the Processing is the collection, recording, organisation, analysis, consultation, use, retrieval, disclosure by transmission, verification, alignment, erasure, and destruction of the Protected Data.
- 2.5 The relevant categories of the Data Subjects are Your clients and/or the directors, shareholders, officers, agents, and/or representatives of Your clients. The Protected Data of such Data Subjects includes without limitation their respective names, current and previous postal addresses, email addresses, employer, bank or building society account details (including sort code and account number), National Insurance or social security number, tax identification numbers, passport or national identity card details and numbers, tax codes, driving licence or shooting licence details, income streams, shareholdings, directorships, gender, dates of birth, nationalities, rights to work and/or reside in the UK, and criminal convictions.

3. YOUR OBLIGATIONS

- 3.1 You will:
 - 3.1.1 have at all times during the term of this Agreement appropriate technical and organisational measures to ensure a level of security appropriate to the risk to protect any Protected Data, and no less effective than Our measures stipulated on the Security Page as at the date of the Agreement;
 - 3.1.2 provide clear written instructions to Us for the Processing of Protected Data to be carried out under this Agreement; and
 - 3.1.3 ensure that You have all the necessary licences, permissions, and consents from Data Subjects;
 - 3.1.4 ensure that You have an applicable legal basis for the transfer of Protected Data to Us and for Our Processing thereof;
 - 3.1.5 not unreasonably withhold, delay, or make conditional Your agreement to any change or amendment requested by Us in order to ensure that We (and each sub-Processor) comply with the Data Protection Legislation; and
 - 3.1.6 on first demand fully indemnify Us (and keep Us fully indemnified) from and against any and all loss, liability, damages, costs, fees, claims and expenses (including without limitation any fines or penalties imposed by Supervisory Authorities) which We may incur or suffer out of, under, or in connection with any breach of this DPA or the Data Protection Legislation by You.
- 3.2 You additionally warrant and represent that:
 - 3.2.1 You have and will, throughout the term of this Agreement, maintain (at Your own cost and expense) all relevant regulatory registrations and notifications as required from time to time under the Data Protection Legislation; and
 - 3.2.2 You have undertaken appropriate due diligence in relation to Our Processing operations and are satisfied that: (i) Our Processing operations are suitable for the purposes for which You propose to use the Software and engage Us to Process the Protected Data; and (ii) We have sufficient expertise, reliability, and resources to implement technical and organisational measures that meet the requirements of the Data Protection Legislation.
- 3.3 You acknowledge that We may use meta-data, aggregated data, statistics, and anonymised information derived from the Personal Data We receive from You which cannot be identified as originating or deriving directly from such Personal Data and cannot be reverse-engineered by a third party such that it can be so identified, for any purpose whatsoever.

4. OUR OBLIGATIONS

- 4.1 We will only Process the Protected Data to the extent, and in such a manner, as is necessary for the fulfilment of Our obligations under this Agreement in accordance with Your written instructions. We will not Process the Protected Data for any other purpose or in a way that does not comply with this DPA or the Data Protection Legislation. We will immediately notify You if, in Our opinion, Your instruction would not comply with the Data Protection Legislation (and We will be entitled to cease performing the relevant services or providing access to or use of the Software until We and You have agreed appropriate amended instructions which are not infringing).
- 4.2 We will promptly comply with any request or instruction from You requiring Us to amend, transfer, delete or otherwise Process the Protected Data, or to stop, mitigate or remedy any unauthorised Processing.
- 4.3 We will maintain the confidentiality of all Protected Data and will not disclose Protected Data to third parties unless You or this DPA specifically authorises the disclosure, or as required by law. If a law, court, regulator, or Supervisory Authority requires Us to Process or disclose Protected Data, We will first use commercially reasonable efforts to inform You of the legal or regulatory requirement and give You an opportunity to object or challenge the requirement, unless this is prohibited under applicable laws.
- 4.4 We will reasonably assist You, in a manner consistent with Our role as Processor, with meeting Your compliance obligations under the Data Protection Legislation, taking into account the nature of Our Processing and the information available to Us, including in relation to Data Subject rights, data protection impact assessments, and reporting to and consulting with Supervisory Authorities. To the extent legally permitted, You will be solely responsible for Our reasonable costs arising from such assistance.
- 4.5 We will use Our commercially reasonable efforts to notify You of any changes to Data Protection Legislation that may adversely affect Our performance of Our obligations under this Agreement.
- 4.6 You acknowledge that We are free to use metadata, statistics and such other information derived from the Protected Data We receive from You which cannot be identified as originating or deriving directly from such Protected Data and cannot be reverse-engineered by a third party such that it can be so identified, for any purpose whatsoever.
- 4.7 We will ensure that Our employees are bound by confidentiality obligations and use restrictions in respect of the Protected Data.

5. SECURITY

- 5.1 We will throughout the duration of each Order Form implement appropriate technical and organisational measures against unauthorised or unlawful Processing, access, disclosure, copying, modification, storage, reproduction, display or distribution of Protected Data, and against accidental or unlawful loss, destruction, alteration, disclosure or damage of Protected Data including, but not limited to, the measures stipulated on the Security Page as at the date of this Agreement.
- 5.2 We may update the security measures from time to time, provided they do not result in a reduction in the security over the Protected Data to which they apply. We will maintain an up-to-date written record of Our then-current security measures, which We will provide to You on request.
- 5.3 We will implement such measures to ensure a level of security appropriate to the risk involved, including as appropriate:
 - 5.3.1 the pseudonymisation and encryption of Protected Data;
 - 5.3.2 the ability to ensure the ongoing confidentiality, integrity, availability and resilience of Processing systems and services;
 - 5.3.3 the ability to restore the availability and access to Protected Data in a timely manner in the event of a physical or technical incident; and
 - 5.3.4 a process for regularly testing, assessing, and evaluating the effectiveness of security measures.

6. PERSONAL DATA BREACH

- 6.1 We will without undue delay notify You of any Personal Data Breach relating to Your Protected Data.
- 6.2 We will, subject to paragraph 6.3, reasonably co-operate with You in Your handling of any Personal Data Breach, including:
 - 6.2.1 assisting with any investigation;
 - 6.2.2 making available all relevant records, logs, files, and other materials required to comply with all Data Protection Legislation; and
 - 6.2.3 taking reasonable and prompt steps to mitigate the effects and to minimise any damage resulting from the Personal Data Breach.
- 6.3 In the event of a Personal Data Breach that was not Our or Our sub-Processors' fault, We will reasonably cooperate with You with reasonable costs and expenses to be covered entirely by You.
- 6.4 We will not inform any third party of any Personal Data Breach without first obtaining Your prior written consent, except when required to do so by law, to maintain any policy of insurance, or to maintain regulatory or equivalent certifications.
- 6.5 Subject to paragraph 6.3, You have the sole right to determine and responsibility to action:
 - 6.5.1 whether to provide notice of the relevant Personal Data Breach to any Data Subjects, Supervisory Authorities, regulators, law enforcement agencies or others, as required by law or regulation or in Your discretion; and
 - 6.5.2 whether to offer any type of remedy to affected Data Subjects, including the nature and extent of such remedy.

7. CROSS-BORDER TRANSFERS OF PROTECTED DATA

- 7.1 If an adequate protection measure for the international transfer of Protected Data is required under Data Protection Legislation (and has not otherwise been arranged by the parties), the Standard Contractual Clauses will be incorporated into this DPA.
- 7.2 We and You will ensure that whenever Protected Data is transferred outside the European Economic Area and the United Kingdom ("GDPR Territories"):
 - 7.2.1 such Protected Data is Processed in a territory which is subject to a current finding by both the European Commission (or, as applicable, the UK government) under the Data Protection Legislation that the territory provides adequate protection for the privacy rights of individuals;
 - 7.2.2 participate in a valid cross-border transfer mechanism under the Data Protection Legislation, so that We and You can ensure that appropriate safeguards are in place to ensure an adequate level of protection with respect to the privacy rights of individuals as required by Article 46 of the GDPR; or
 - 7.2.3 otherwise ensure that the transfer complies with the Data Protection Legislation.
- 7.3 In the case of any Processing of Protected Data outside of the GDPR Territories as at the date of this DPA, We have identified in the Appendices the relevant transfer mechanism. We will promptly inform You of any change to such mechanisms.

8. SUB-PROCESSORS

- 8.1 You authorise Us to use sub-Processors who as at the date of this Agreement are: (i) Microsoft Corporation (Azure), UK South/UK West (primary), (ii) Progentic AI, 11297 Majestic Prince Cir, Frisco, TX 75035-1187 and (iii) Compliance On Demand Limited, 71-75 Shelton Street, Covent Garden,

London WC2H 9JQ. These sub-Processors include but are not limited to the general categories of data storage, cloud hosting (including data centres and providers of virtual software environments) and IT support.

- 8.2 We will provide notifications of any proposed changes Our appointed sub-Processors by posting to details thereof to the Sub-Processor Page, which will have a mechanism allowing You to subscribe to notifications of proposed new or replacement sub-Processors. Within ten (10) calendar days of such notification being posted to the Sub-Processor Page, You may (by way of written notification to Us), in which case paragraph 8.4 will apply.
- 8.3 We may only substitute a sub-Processor or add a new sub-Processor to Process the Protected Data if:
- 8.3.1 We have posted the relevant details thereof to the Sub-Processor Page in accordance with paragraph 8.2;
 - 8.3.2 We enter into a written contract with the sub-Processor that contains terms similar to those set out in this DPA; and
 - 8.3.3 We maintain control over all Protected Data We entrust to the relevant sub-Processor.
- 8.4 Where, pursuant to paragraph 8.2, You object to the appointment of an additional or replacement sub-Processor on reasonable grounds relating to Data Protection Legislation or other relevant regulations, We will have the right to cure the objection through one of the following options (to be selected at Our sole discretion):
- 8.4.1 We will cancel Our planned use of sub-Processor or will offer an alternative plan to provide the Services without using such sub-Processor;
 - 8.4.2 We will take the corrective steps, if any, identified by You in Your objection as sufficient to remove Your objection, and proceed to use the sub-Processor; or
 - 8.4.3 We may cease to provide, or You may agree not to use (temporarily or permanently), the particular aspect of the Software or the Additional Services that would involve the use of such sub-Processor, subject to a mutual agreement between You and Us to adjust the remuneration in respect thereof considering the reduced scope.
- 8.5 Where the sub-Processor fails to fulfil its obligations under such written agreement, We remain fully liable to You for the sub-Processor's performance or non-performance of the relevant obligations.

9. COMPLAINTS, DATA SUBJECT REQUESTS, AND THIRD-PARTY RIGHTS

- 9.1 We will take such technical and organisational measures and promptly provide such information to You as required by Data Protection Legislation, at Your expense, to enable You to comply with:
- 9.1.1 the rights of Data Subjects under the Data Protection Legislation; and
 - 9.1.2 information or assessment notices served on You by any Supervisory Authority under the Data Protection Legislation.
- 9.2 We will notify You immediately if We receive any complaint, notice, or communication that relates directly or indirectly to the Processing of the Protected Data or to either party's compliance with the Data Protection Legislation.
- 9.3 If We receive a request from a Data Subject to exercise any of their related rights under the Data Protection Legislation, We will instruct the Data Subject to make their request directly to You. You will be responsible for responding to any such request.
- 9.4 We will at Your expense give Our commercially reasonable co-operation and assistance to You in responding to any complaint, notice, communication or Data Subject request.
- 9.5 We will not disclose the Protected Data to any Data Subject or to a third party other than at Your request or instruction, as provided for in this DPA or as required by law.

10. DATA RETURN AND DESTRUCTION

- 10.1 We will give You the ability to access, extract and delete the relevant portion Your Protected Data stored in Our systems solely for the relevant Retention Period (as defined in the Agreement). Following the final Retention Period, We will disable Your account and delete all Your Protected Data, save to the extent We are required by any applicable law to retain some or all of such Protected Data. In such event We will extend the protections of this DPA to such retained Protected Data and limit any further Processing of such Protected Data only to those limited purposes for which, and only for so long as, such retention is required by applicable law.
- 10.2 This requirement will not apply to Protected Data archived on Our backup systems which are not reasonably accessible, provided such Protected Data is deleted promptly if such backups become reasonably accessible (such as by Us using them to restore Our systems).

11. RECORDS AND AUDIT

- 11.1 We will keep detailed, accurate and up-to-date written records regarding any Processing of Protected Data We carry out for You ("**Records**") and provide You with copies of the Records upon request.
- 11.2 No more than once during any twelve-month (12-month) period, on Your request We will at Your expense provide You with the relevant information from Our own information security audit to evidence Our compliance with this DPA and provide the summary results to You. If such summary does not address a specific query concerning Our compliance with this DPA that You had previously communicated to Us in writing, You may undertake (no more than once during any twelve-month (12-month) period) a further audit or inspection of Our compliance with this DPA, subject to You:
- 11.2.1 giving at least three (3) months' written notice to Us of any request to conduct any such audit or inspection;
 - 11.2.2 ensuring that all information obtained or generated by You or a professionally qualified auditor mandated by You in connection with such audits and inspections are kept strictly confidential (save for disclosure to the relevant Supervisory Authority or as otherwise required by law);
 - 11.2.3 permitting Us or any of Our staff to accompany and escort You and/or Your mandated auditors or representatives at all times during any such audit or inspection;
 - 11.2.4 ensuring that any such audits or inspections will be undertaken during Our normal business hours and with minimal disruption to Our business and the respective businesses of Our Affiliates and other customers; and
 - 11.2.5 promptly (and in any event within thirty (30) calendar days of any such audit or inspection) reimbursing to Us, in full and cleared funds, the reasonable costs and expenses incurred by Us in enabling, facilitating, and contributing to such audits and inspections and assisting with the provision of information to You pursuant to such audits and inspections.
- 11.3 Where required by Data Protection Legislation, We will exercise relevant audit rights We have in connection with Our sub-Processors' compliance with their obligations regarding Your Protected Data, and provide You with a summary of the audit results.
- 11.4 The audit rights set out herein are Your only contractual rights (and Our only contractual obligations) in connection with the auditing of Our Processing of Protected Data. Nothing in this DPA will prevent or is intended to undermine the rights and powers granted to Data Subjects or Supervisory Authorities, and We will submit to any audits required by a Supervisory Authority or Data Protection Legislation.

SECURITY PAGE

1. Azure Infrastructure and Sub-processors

The Service is hosted on Microsoft Azure. Microsoft acts as a Sub-processor under the *Microsoft Products and Services Data Protection Addendum* (the “Microsoft DPA”, available at <https://aka.ms/DPA>). AML DealCheck’s obligations at the infrastructure layer are satisfied to the extent Microsoft’s own commitments meet or exceed them.

2. Security

We implement technical and organisational measures proportionate to the risk, including: TLS 1.2+ and AES-256 encryption; role-based access via Microsoft Entra ID with MFA; Azure network isolation and monitoring; application-level vulnerability testing; and documented incident response procedures.

3. Audit

We shall make available information reasonably necessary to demonstrate Article 28 compliance. Audits: once per year, 30 days’ notice, at Your cost.

We may satisfy audit requests by providing third-party certifications (ISO 27001, SOC 2). You have no independent right to audit any Sub-processor under this DPA.